GraphRAG-Net: End-to-End System Architecture

Hybrid Graph-Augmented Cyber Threat Intelligence Reasoning via Dual-Channel Retrieval, Hetero-GraphSAGE Embeddings & Platt-Calibrated Confidence Scoring

Peer-Reviewed Methodology | MITRE ATT&CK v14 / STIX 2.1 | PyG Hetero-GraphSAGE

TRACK I — OFFLINE KNOWLEDGE GRAPH ETL & STRUCTURAL GNN LEARNING

Structured Ontologies

- **MITRE ATT&CK Enterprise (STIX 2.1)**
- MITRE CAPEC (Attack Patterns)
- MITRE CWE (Weakness Enumeration)
- NVD CVE Database (CVSS v3.1 Scores)
- CISA Known Exploited Vulns (KEV)

Unstructured CTI Feeds

- **Vendor Threat Intelligence Reports**
- CISA / US-CERT Security Advisories
- Mandiant / CrowdStrike APT Bulletins
- Cybersecurity News & OSINT Articles
- DFIR Incident Post-Mortem Analyses

Operational Telemetry

- **Malware Dynamic Sandbox Reports**
- Network PCAP & C2 Flow Artifacts
- Endpoint Sysmon & Windows Event Logs
- Threat Actor Tool & Binary Hashes
- Active Directory Kerberos & SMB Logs

PREPROCESSING — Adaptive Semantic Text Chunking & Lexical Inverted Index Store

- **Dynamic Cosine Segmentation: Breakpoint threshold T = μ + k·σ over domain embedding vector distances**
- Multi-Ontology Sentence Embedding: text-embedding-ada-002 | Extracts coherent context passages for BM25 Channel

STAGE 1 — Multi-Ontology Extraction & 3-Tier Entity Disambiguation Engine

Schema-Constrained LLM Extraction

Strict 11-Entity Ontology Schema:
ThreatActor, AttackPattern, Malware, Vulnerability, CWE, CourseOfAction, Identity, Infrastructure, Tool

Constrained JSON Prompting (Groq LLaMA-3 / OpenAI):
Enforces exact syntactic JSON output schema with known_id_hint lookups

Anti-Hallucination Guardrails:
Suppresses fabricated entity types; restricts relation predicates to typed ontology edges

Extracted Triplet Provenance:
Preserves source URI, confidence logit, and text chunk character offsets

3-Tier Entity Resolution & Coreference Linking

- **Tier 1: Canonical Alias Index Lookup (Exact STIX Match)**
  Resolves aliases (e.g. APT28 = Fancy Bear = Sofacy = G0007) to canonical STIX ID
- **Tier 2: RapidFuzz token_sort_ratio String Matching**
  Score ≥ 97: Automatic Node Merge | 88 ≤ Score < 97: SOC Analyst Review Queue
- **Tier 3: Domain Vector Cosine Similarity Alignment**
  Cosine similarity Score_align ≥ 0.80 using threat report contextual embeddings
- **Global Identity Graph Merge & Duplicate Pruning**
  Unifies synonyms while preserving source attribution and reference provenance

Neo4j Heterogeneous Knowledge Graph — 15,000+ Typed Nodes • 150,000+ Multi-Relational Directed Edges

- **Node Entity Classes: ThreatActor (136) | AttackPattern (627) | Malware (582) | Vulnerability (1,248) | Weakness (312) | CourseOfAction (390)**
- Multi-Relational Edges: USES_MALWARE, EXPLOITS_VULNERABILITY, MAPS_TO_CWE, MITIGATES, ATTRIBUTED_TO, TARGETS_SECTOR

STAGE 2 — Structural GNN Representation Learning (Heterogeneous GraphSAGE)

PyG HeteroData Graph

Graph Tensor Pipeline:
Converts Neo4j schema to PyTorch Geometric HeteroData tensors

Initial Node Features:
64-D SBERT semantic vectors for textual entity names/descriptions

Multi-Relational Adjacency:
Typed edge indices per relation r ∈ R across heterogeneous graph

Hetero-GraphSAGE Message Passing

Layer-k Multi-Relational Neighborhood Aggregation:

$$h_N(v)^{(k)} = AGG_{r \in R} (\{ W_r \cdot h_u^{(k-1)} : u \in N_r(v) \})$$

Target Node Feature Update with Skip-Connection:

$$h_v^{(k)} = \sigma(W_{self} \cdot [h_v^{(k-1)} \,||\, h_N(v)^{(k)}])$$

Architecture: 2 SAGE Layers | Hidden Dim: 256 | Output Dim: 128-D

Link Prediction Training

Binary Cross-Entropy (BCE) Loss:
Optimized with N = 5 negative sampled unobserved edges per positive

Adam Optimizer (lr=0.001, wd=1e-4):
Trained 100 epochs with edge dropout p=0.2

Link Prediction Performance:
Mean Rank: 1.520 | Hits@10: 97.2%

Learned Topological Embedding Store — 128-Dimensional Node & Edge Vectors Capturing Deep Multi-Hop Structural Manifold

- **Encodes relational proximity, indirect attack paths, and implicit CVE-to-Mitigation associations without explicit graph hops**
- Stored in FAISS / PyTorch Vector Index for real-time high-throughput cosine similarity retrieval during online query execution

TRACK II — ONLINE DUAL-CHANNEL RETRIEVAL, REASONING & CONFIDENCE CALIBRATION

ANALYST QUERY — Natural Language Cyber Threat Query Input

Query: "APT29 credential access techniques, LSASS dumping mechanisms, and enterprise mitigations"

Adaptive Semantic BM25 Text Chunks

STAGE 3 — Dual-Channel Hybrid Retrieval & Reciprocal Rank Fusion (RRF)

Channel 2: Graph Structural Retrieval

Dense Vector Similarity over GraphSAGE Manifold:
Cosine similarity between query representation and 128-D GNN embeddings

Topological & Multi-Hop Proximity:
Surfaces implicit graph associations, related TTPs, and structural neighbors

Retrieval Output:
Top-K topologically coherent graph seed nodes and relation contexts

Channel 1: Lexical BM25 Retrieval

Sparse Lexical Inverted Index Search:
Matches query tokens over semantic text chunks and STIX descriptions

Precision on Exact Technical Indicators:
High recall for CVE IDs, registry keys, malware names, and file paths

Retrieval Output:
Top-K candidate text passages and explicit entity mentions

Reciprocal Rank Fusion (RRF, k=60)

$$Score_{RRF}(d) = \sum_{c \in \{BM25, GNN\}} 1 / (60 + rank_c(d))$$

- **Balances exact lexical IOC matches against deep multi-hop graph topological structure without ad-hoc score normalization**
- **Surfaces Provenance Consensus Badges: [BM25-only: Lexical] | [GNN-only: Structural] | [HYBRID_BOTH: High-Confidence Agreement]**

STAGE 4 — Contextual Subgraph Triplet Extraction & Path Merging

1-Hop & 2-Hop Subgraph Extraction

Seed Entity Expansion:
Expands 1-hop and 2-hop relational neighborhoods around top RRF candidate entities

Contextual Triplet Recovery:
Surfaces multi-hop causal attack paths (e.g. ThreatActor → Malware → Vuln → CWE)

Path Merging & Relevance Filtering

Cross-Channel Consistency:
Validates that retrieved graph paths co-occur with lexical evidence text passages

Disjoint Subgraph Pruning:
Eliminates disconnected graph noise, loops, and low-relevance ungrounded triplets

Multimodal Evidence Bundle

Structured Knowledge Context:
JSON-formatted graph triples + source citations and multimodal channel provenance badges

Conditioned LLM Prompting:
Compact grounded evidence context window feeding downstream LLM reasoning engine

STAGE 5 — Grounded LLM Reasoning Engine (Attack Chain & Mitigation Synthesis)

1. Attack Chain Reconstruction

Multi-Stage Kill Chain Progression:
Phase 1: Initial Access (T1566 Spearphishing Attachment)
Phase 2: Execution & Persistence (T1059 PowerShell, T1547 Registry Keys)
Phase 3: Credential Access (T1003 OS Credential Dumping / LSASS Injection)
Phase 4: Lateral Movement & Exfiltration (T1550 Pass the Hash, T1048 Non-C2)

2. Actionable & Grounded Mitigations

MITRE CourseOfAction Grounding:
[M1043 Credential Protection] Enforce LSA Protection / RunAsPPL against LSASS access
[M1046 Boot Integrity] Enable Windows Credential Guard & Virtualization-Based Security
[M1032 Multi-Factor Auth] Mandate FIDO2 hardware tokens across enterprise logins
[M1038 Execution Prevention] Block unapproved script interpreters and lolbin execution

STAGE 6 — Platt-Calibrated 9-Feature Confidence Engine & Uncertainty Quantification

9-Feature Metric Vector x ∈ R^9

- **Retrieval (4): top1_score, top1_top2_margin, n_supporting_paths, avg_path_length**
- **Evidence (3): entity_jaccard, evidence_cosine_sim, channels_agree**
- **Reasoning (2): self_consistency_score, unsupported_claim_ratio**
- Feature Extraction: confidence_scorer/feature_extractor.py over retrieval + LLM traces

Platt Sigmoid Scaling Calibration

$$P(correct \mid x) = 1 / (1 + \exp(-(w^T x + b)))$$

- **Empirical Performance: Expected Calibration Error ECE = 0.1285 | AUROC = 0.9850**
- **Sub-Scores: Retrieval Strength (0.54) | Cross-Channel Agreement (0.75) | LLM Consistency (0.85)**
- Decision Policy: P ≥ 0.80: High Trust | 0.50 ≤ P < 0.80: Medium (Review) | P < 0.50: Abstain/Flag

STAGE 7 — Explainability Output & Security Operations Center (SOC) Interactive Dashboard

Structured CTI Report

- **Attack Chain Progression across MITRE Tactics**
- Actionable Defense Mitigations mapped to IDs
- Direct citations to STIX, CVE, CWE, and Advisories

Calibrated Confidence Card

- **Calibrated Trust Score: P(correct) = 0.94 (High)**
- Granular Sub-Scores: Retrieval, Agreement, Consistency
- Diagnostic Warnings for low-density graph regions

Interactive 2D Graph Visualizer

- **Color-coded Vis-Network Graph (Actors, TTPs, CVEs)**
- Multimodal Provenance Badges (BM25 vs GNN vs Both)
- Clickable node inspection & multi-hop traversal

FastAPI Production REST Endpoints

- **POST /api/search: End-to-end reasoning & scoring**
- GET /api/stats: Graph & PyG embedding metrics
- POST /api/calibrate: Re-calibrates weights on feedback

Data Ingestion & KG | Hetero-GraphSAGE GNN | Dual-Channel RRF | Evidence Ranking | LLM Reasoning | Platt Confidence Scorer | SOC Dashboard & UI

Empirical Validation: Hetero-GraphSAGE Hits@10 = 97.2%, Mean Rank = 1.520 | Platt Sigmoid ECE = 0.1285, AUROC = 0.9850 | IEEE/ACM Publication Level